56

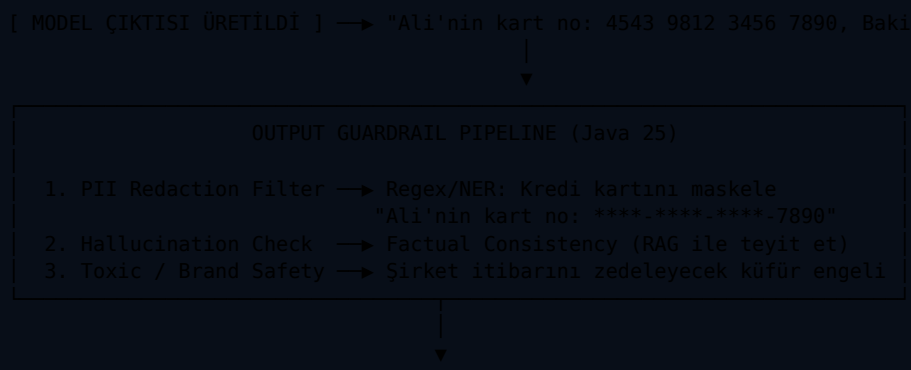
BÖLÜM: AI GÜVENLİĞİ, GÖZLEMLENEBILIRLIK & MAANG MÜLAKAT USTALIĞI | MODULE: AI SECURITY, OBSERVABILITY & THE MAANG INTERVIEW MASTERY RUBRIC

Çıktı Doğrulama ve Hallucination Filtresi (Structured Guardrails)

Output Guardrails: Output Verification, PII Redaction & Hallucination Suppression

🤖 AI Mimarisi & Veri Akış Şeması

🤖 AI Architecture & Flow



💡 Aptala Anlatım (ELI5 Metaforu)

💡 ELI5 Metaphor

🇹🇷 TÜRKÇE (ELI5)

Canlı televizyon yayınlarında küfürlü veya sakıncalı bir durum olduğunda yayını hemen kesebilmek için 7 saniyelik bir gecikme koyarlar (Canlı Yayın Filtresi). Çıktı Doğrulama (Output Guardrail) tam olarak bu filtredir! Model bir cevap ürettiğinde, o cevap doğrudan kullanıcının ekranına düşmez. Önce güvenlik odasından geçer: 'Cevabın içinde kredi kartı veya müşteri TC kimlik numarası sızmış mı?' (PII Redaction), 'Model kafasından uydurma bir sözleşme maddesi mi yazdı?' (Hallucination Check). Temizse onay damgası basılır ve ekrana verilir!

🇬🇧 ENGLISH (ELI5)

Live television broadcasts maintain a mandatory 7-second buffer to dump profanities or inappropriate wardrobe malfunctions before signals reach public homes. Output Guardrails provide this exact defensive buffer for LLMs! When the model finishes token generation, the output is not displayed blindly. It passes through an automated sanitization audit: Are credit card numbers leaking? (PII Redaction), Did the model invent a non-existent company policy? (Hallucination Check). Only sanitized text reaches the user!

🔍 MAANG Seviyesi Teknik Derinlik

🇹🇷 MAANG DERİNLEMESİNE ANALİZ

Çıktı Güvenliği Katmanları: 1) PII Redaction (Kişisel Veri Maskeleme): Kredi kartı (Luhn algoritması), e-posta, telefon ve TC kimlik numaraları tespit edilerek **** şeklinde maskelenir. 2) Structural Schema Validation: JSON dönmesi gereken bir modelin çıktısı Jackson/JsonSchema ile doğrulanır; şema bozuksa istemciye 500 hatası gitmez, model sessizce arkada tekrar çağrılır (Self-Healing JSON). 3) Hallucination Suppression: RAG dokümanında geçmeyen tarih ve para miktarları regex ile tespit edilip elenir.

🔍 MAANG-Level Technical Deep-Dive

🇬🇧 MAANG TECHNICAL DEEP-DIVE

Output Guardrail Engineering: 1) Automated PII Redaction: Deterministic regex and NER scanners inspect completions for payment card numbers (validating against the Luhn algorithm), social security numbers, and email patterns, replacing them with tokens (`[REDACTED]`). 2) Self-Healing Schema Validation: If a structured output response fails JSON deserialization, the raw error trace is fed back into a rapid repair prompt to synthesize a corrected payload before throwing runtime errors. 3) Semantic Toxicity & Compliance: Enforce brand and legal boundaries, blocking model-generated liability claims.

⚡ Java 25, Spring AI & LangChain4j Kodu

⚡ Java 25 & OpenAI Implementation

```java
// Java 25: Hassas Veri (PII) ve Kredi Kartı Maskeleme Filtresi (Output Guardrail)
import java.util.regex.Pattern;

public class PiiRedactionOutputGuard {
    private static final Pattern CREDIT_CARD_PATTERN = Pattern.compile(
        "\\b(?:\\d{4}[ -]?){3}\\d{4}\\b"
    );

    public static String redactSensitiveData(String modelOutput) {
        if (modelOutput == null) return "";
        // Kredi kartı numaralarını maskele: ****-****-****-1234
        return CREDIT_CARD_PATTERN.matcher(modelOutput).replaceAll("****-****-****-XXXX");
    }
}

void main() {
    String rawLlmResponse = "Müşteri ödemeyi tamamladı. Kart: 4532-1234-5678-9012 onaylandı.";
    String sanitized = PiiRedactionOutputGuard.redactSensitiveData(rawLlmResponse);

    IO.println("Ham Model Çıktısı   : " + rawLlmResponse);
    IO.println("Maskelenmiş Güvenli : " + sanitized);
}
```

⚠️ Halüsinasyon, Güvenlik & Mülakat Tuzağı

⚠️ Hallucination & Interview Trap

🇹🇷 MÜLAKAT TUZAĞI VE HALÜSİNASYON

Yasal Sorumluluk Riski: Modelin kullanıcılara 'Tıbbi teşhis' veya 'Kesin hukuki tavsiye' vermesi şirketinizi milyonlarca dolarlık davalarla karşı karşıya bırakabilir. Çıktı filtrelerinde otomatik olarak 'Bu bir yatırım/sağlık tavsiyesi değildir' yasal feragatnamesi (Disclaimer) eklenmelidir.

🇬🇧 INTERVIEW TRAP & HALLUCINATION RISK

Legal liability vulnerability: Allowing an enterprise model to emit definitive medical diagnoses or binding financial advice triggers severe regulatory and civil liability. Output filters must append automated statutory disclaimers ('This information is advisory only and does not constitute formal financial counsel').

🎯 Mülakatta Hatırlanacak Altın Çıkarımlar

- Model çıktıları asla filtrelenmeden doğrudan son kullanıcıya sunulmamalıdır.
- Kredi kartı ve kişisel veriler (PII) regex ve Luhn algoritmalarıyla maskelenmelidir.
- Şema doğrulaması başarısız olursa Self-Healing mekanizması ile model tekrar tetiklenmelidir.

🎯 Key Takeaways for the Interview

- Never display raw LLM completions directly to users without passing output guardrails.
- PII and financial card data must be scrubbed deterministically via regex and Luhn checks.
- Failed schema generations should trigger self-healing prompt retries automatically.